

AVALIAÇÃO INTERMEDIÁRIA

Quanto custa um *alerta*?

Avaliação rigorosa, limiar de decisão e custo operacional.

CIBERSEGURANÇA APLICADA COM INTELIGÊNCIA ARTIFICIAL · 2026-2

FORMATO	MODO	PESO	CONTEÚDO
Individual ou em dupla	Assíncrono · entrega pelo Blackboard	10,0 pontos (rubrica, seção 7)	Parte A (a-f) · Parte B (g-j)

1. Objetivos

Ao concluir esta avaliação, você será capaz de:

- Explicar por que a classe que o modelo devolve depende de um limiar arbitrário e extrair a pontuação por trás dela.
- Comparar ROC-AUC e PR-AUC e escolher a métrica adequada para uma classe rara.
- Varrer limiares de decisão e ler o efeito de cada um em falsos positivos, falsos negativos e volume de alertas.
- Traduzir erros em custo operacional (custo fixo e custo dependente do valor) e escolher o limiar que minimiza esse custo, respeitando a capacidade de quem responde aos alertas.
- Distinguir a estimativa otimista da validação cruzada aleatória da estimativa honesta do split temporal.
- Comparar Random Forest e XGBoost em um problema de fraude real e identificar limitações e vieses do dataset.

2. Contexto: o que você precisa saber antes de começar

DA PONTUAÇÃO À DECISÃO

Todo classificador probabilístico devolve, para cada exemplo, uma pontuação entre 0 e 1 (`predict_proba`). O método `predict()` apenas compara essa pontuação com 0,5 e devolve a classe. O 0,5 é o valor padrão da biblioteca, não uma decisão de segurança: nada garante que ele seja o melhor corte para o seu problema. Quando as pontuações se concentram perto de 0 e de 1, mover o limiar muda pouco; quando há uma região povoada entre 0,2 e 0,8, cada centésimo de limiar transfere exemplos de um lado para o outro da matriz de confusão. Por isso a primeira pergunta de quem vai operar um detector não é "qual a acurácia?", e sim "onde eu corto?".

O QUE UM ERRO CUSTA

Em segurança os dois tipos de erro têm preços diferentes e raramente comparáveis. Um falso positivo consome tempo de analista (triagem, investigação, encerramento) ou gera fricção para um cliente legítimo (compra bloqueada, confirmação por SMS). Um falso negativo é um ataque que entra sem resposta ou uma fraude que passa: o custo inclui a perda direta, a contenção e, muitas vezes, dano reputacional. Quando os dois custos são conhecidos, mesmo que estimados, o limiar deixa de ser opinião:

$$\text{custo total} = \text{FP} \times \text{C_FP} + \text{FN} \times \text{C_FN}$$

O modelo fornece TP, FP e FN para cada limiar; o negócio fornece C_FP e C_FN. Basta varrer os limiares e escolher o de menor custo. O custo do falso negativo pode ser fixo (o custo médio de um incidente) ou variar por exemplo (o valor da transação fraudulenta que passou). Como os custos são hipóteses, a análise inclui testar a sensibilidade: se o C_FN fosse cinco vezes maior, a decisão mudaria?

A FALÁCIA DA TAXA-BASE

Imagine 10.000 fluxos por dia com um único ataque. Um detector com 99% de recall e apenas 1% de taxa de falsos positivos parece excelente. Mas ele gera 0,99 alerta verdadeiro e cerca de 100 alertas falsos por dia: a precisão é de 1%. Esse argumento, clássico na literatura de detecção de intrusão, mostra que em classes muito raras a taxa de falsos positivos precisa ser extremamente baixa para o detector ser operável, e que a acurácia e a curva ROC escondem o problema, porque ambas são dominadas pela classe majoritária.

ROC OU PRECISION-RECALL

A curva ROC coloca a taxa de falsos positivos no eixo x, cujo denominador é o total de exemplos negativos. Com 85 mil transações legítimas, 24 falsos positivos são invisíveis para ela. A curva Precision-Recall coloca a precisão no eixo y, cujo denominador é o número de alertas; 24 falsos positivos em 107 alertas movem muito. Para classes raras, a PR-AUC (average precision) é a área que descreve o que o analista vê. Uma referência útil: a PR-AUC de um modelo aleatório é igual à prevalência da classe positiva, e a ROC-AUC de um modelo aleatório é 0,5 em qualquer prevalência. É comum que as duas áreas ordenem modelos de forma diferente; quando isso acontece, a PR decide.

CUSTO E CAPACIDADE SÃO RESTRIÇÕES DIFERENTES

O limiar de custo mínimo pode gerar mais alertas do que o time consegue triar. Nesse caso o custo mínimo é ficção: o excedente vira fila, e fila vira falso negativo não contabilizado. A capacidade (alertas por turno, por dia, por período) é uma segunda restrição, independente do custo. Quando as duas conflitam, o limiar não resolve o problema: a decisão passa a ser de gestão (aumentar a capacidade com mais analistas ou automação de triagem, ou aceitar o recall que cabe no time). Um parecer honesto apresenta os limiares candidatos lado a lado: o corte padrão 0,5, o de F1 máximo, o de custo mínimo e o de menor custo dentro da capacidade.

VALIDAÇÃO HONESTA

A validação cruzada estratificada com embaralhamento mistura, em cada fold, exemplos do início e do fim de uma campanha de ataque: o modelo treina com informação do futuro. A estimativa fica otimista. O split temporal (treinar no passado, testar no futuro) reproduz o que a operação vai ver na semana seguinte e produz um número mais baixo e mais honesto. A validação cruzada continua útil para escolher hiperparâmetros e medir variância; o número reportado ao gestor, porém, é o temporal. A diferença entre os dois é uma medida do drift dentro do próprio dataset. No Roteiro 2, o recall do Bot caiu de 0,96 no split aleatório para 0,16 no temporal: mesmo modelo, mesma classe.

LIMITAÇÕES E VIÉS EM MODELOS DE SEGURANÇA

Cinco fontes aparecem em quase todo dataset da área. **Taxa-base:** a precisão desaba quando a classe é rara. **Viés de rótulo:** o rótulo vem de um detector anterior ou de contestações de clientes; o que ninguém viu está marcado como legítimo, e o modelo aprende a não ver. **Origem de laboratório:** tráfego gerado em ambiente controlado tem rótulo perfeito e realismo limitado. **Drift:** o padrão muda com o tempo e o modelo envelhece. **Erro desigual:** o custo dos falsos positivos costuma recair sobre um grupo específico de usuários, horários ou faixas de valor. Reconhecer essas limitações é parte do que a NIST AI RMF chama de mapear o contexto de um sistema de IA.

3. Materiais

Não há material novo: os dois datasets já estão com você. Você monta o notebook do zero a partir deste enunciado. Os requisitos são os mesmos do Roteiro 2, mais XGBoost: `pip install pandas numpy scikit-learn matplotlib jupyter joblib xgboost`.

ARQUIVO	O QUE É	USO
<code>dados/R2_<codigo>.csv.gz</code>	O dataset que você gerou no Roteiro 2 com <code>meu_dataset.py</code> (não é distribuído de novo; o script regenera o mesmo arquivo).	Parte A
<code>creditcard.csv.gz</code>	O dataset de fraude usado na aula de métricas (284.807 transações, 492 fraudes, features V1 a V28 já transformadas por PCA, Time e Amount).	Parte B

Regras que valem para todos os itens. Use o seu `random_state` (o inteiro impresso pelo `meu_dataset.py` no Roteiro 2) em todo fit, split e validação cruzada. Quem fez o Roteiro 2 em dupla mantém o código e o `random_state` da dupla; quem fez sozinho mantém os seus. Todo achado vem acompanhado do código que o produziu e do número que o sustenta. As respostas discursivas ficam em células Markdown logo abaixo do item, no próprio notebook. Trate a coluna Amount como valor em reais para fins de custo.

A O seu detector de intrusão

A Parte A parte do Random Forest que você treinou no Roteiro 2 sobre o seu próprio recorte do CICIDS2017. O objetivo não é melhorar o modelo, e sim avaliá-lo com rigor e decidir como ele seria operado em um SOC.

a) Reconstruir o modelo e salvá-lo

Recarregue `dados/R2_<codigo>.csv.gz` e aplique a mesma limpeza do item e) do Roteiro 2 (coluna `alertas_ids` fora, infinitos e NaN tratados, duplicatas e rótulos conflitantes removidos). Monte o alvo binário (1 = qualquer ataque, 0 = BENIGN). Faça o split temporal: dentro de cada dia, os primeiros 70% da `ordem_captura` treinam e os 30% finais testam. Treine um Random Forest com `n_estimators=100` e o seu `random_state`.

Salve o modelo e o conjunto de teste na pasta `saida/` com os nomes obrigatórios `avaliacao_<codigo>.joblib` e `avaliacao_<codigo>_teste.csv.gz` (features de teste mais as colunas ataque e Label). Esses dois arquivos serão o ponto de partida dos Roteiros 4 e 5; sem eles, você começará aqueles roteiros do zero.

ENTREGÁVEL · tamanho de treino e teste, prevalência de ataque em cada um, os dois arquivos salvos.

b) Da classe à probabilidade

`predict()` devolve 0 ou 1. Por baixo, o modelo devolve uma pontuação (`predict_proba`) e alguém escolheu 0,5 como corte. Extraia a pontuação de ataque no conjunto de teste e desenhe o histograma das pontuações separado por classe verdadeira, com o eixo y em escala log e uma linha vertical em 0,5.

PERGUNTA B.1

olhando o histograma, onde estão os fluxos em que o modelo tem dúvida? O corte 0,5 passa por uma região vazia ou por uma região povoada?

ENTREGÁVEL · histograma e a contagem de fluxos com pontuação entre 0,2 e 0,8.

c) ROC contra Precision-Recall

Calcule ROC-AUC e PR-AUC (`average_precision_score`) no teste temporal e desenhe as duas curvas lado a lado. Em seguida, calcule o recall da sua classe difícil (a sorteada pelo `meu_dataset.py`) no corte 0,5, usando o rótulo original de teste, e compare com o recall global.

PERGUNTA C.1

as duas áreas contam a mesma história? Qual delas você levaria para uma reunião com o gestor do SOC e por quê?

PERGUNTA C.2

o recall da classe difícil no corte 0,5 é compatível com o recall global? O que isso diz sobre usar um único limiar para todas as classes?

ENTREGÁVEL · as duas áreas, as duas curvas, o recall da classe difícil e o global.

d) Varredura de limiar

Escreva a função `varrer_limiares(y, p, limiares)` que devolve um DataFrame com, para cada limiar, TP, FP, FN, número de alertas, precisão, recall e F1. Rode de 0,05 a 0,95 em passos de 0,05. A função será reutilizada na Parte B, então deixe-a preparada para receber custos (ver item e).

PERGUNTA D.1

qual limiar maximiza o F1? Quantos falsos positivos ele produz a mais (ou a menos) que o corte 0,5?

ENTREGÁVEL · a tabela completa e o limiar de F1 máximo.

e) O custo de um alerta

Cenário do SOC que opera o seu detector: cada falso positivo consome cerca de 8 minutos de um analista de nível 1, custo estimado de R\$ 12 por alerta falso. Cada falso negativo é um ataque que entra sem resposta, com custo médio de contenção estimado em R\$ 2.500. O SOC consegue triar no máximo 10% dos fluxos do período coberto pelo conjunto de teste; calcule esse número.

Estenda `varrer_limiares` para receber `custo_fp` e `custo_fn` e devolver também o custo total de cada limiar. Desenhe custo total contra limiar.

PERGUNTA E.1

qual limiar minimiza o custo total? Quanto ele economiza em relação ao corte 0,5 e ao limiar de F1 máximo?

PERGUNTA E.2

o limiar de custo mínimo respeita a capacidade do SOC? Se não, qual é o menor custo alcançável dentro da capacidade? Qual dos dois você recomendaria e o que muda no argumento se o custo do falso negativo for cinco vezes maior?

ENTREGÁVEL · tabela com custo, gráfico custo contra limiar, os três limiares comparados (custo mínimo, F1 máximo, 0,5) e o limiar dentro da capacidade.

f) Validação: o número que você reportaria

Compare duas formas de estimar a PR-AUC do mesmo Random Forest: validação cruzada estratificada de 5 folds sobre todo o dataset limpo, embaralhando com o seu `random_state`, e o split temporal já feito. Reporte as duas.

PERGUNTA F.1

qual estimativa é mais otimista e por quê? Qual das duas descreve o que o SOC vai ver na semana que vem? Relacione com o que aconteceu com a sua classe difícil no Roteiro 2.

ENTREGÁVEL · as duas PR-AUC (média e desvio dos folds para a validação cruzada).

B Fraude em cartão: Random Forest contra XGBoost

A Parte B usa um dataset real de fraude com prevalência de 0,17%. Os mesmos instrumentos da Parte A são aplicados a um problema em que o custo do erro não é fixo.

g) Dois modelos, duas áreas

Ordene `creditcard.csv.gz` por Time e faça o split temporal: os primeiros 70% do tempo treinam, os 30% finais testam. Treine um Random Forest (`n_estimators=100`, `class_weight="balanced_subsample"`, `min_samples_leaf=2`) e um XGBoost (`scale_pos_weight` igual a negativos dividido por positivos no treino). Para cada modelo, reporte ROC-AUC, PR-AUC e a matriz de confusão no corte 0,5.

PERGUNTA G.1

os dois modelos são ordenados da mesma forma pelas duas áreas? Se não, qual área você usaria para escolher o modelo e por quê?

PERGUNTA G.2

no corte 0,5, os dois modelos erram do mesmo jeito? Descreva a diferença em termos de falsos positivos e falsos negativos.

ENTREGÁVEL · tabela com as duas áreas e a matriz de confusão de cada modelo.

h) Custo com valor real: o falso negativo vale o que a fraude levou

Aqui o custo do falso negativo é o valor da transação fraudulenta que passou (Amount). O custo do falso positivo é a fricção de confirmar a compra com o cliente: R\$ 5 por alerta. Reaproveite `varrer_limiares` passando um vetor de custos por linha (`custo_fn=cc_te["Amount"]`) para os dois modelos e desenhe custo contra limiar para ambos no mesmo gráfico.

PERGUNTA H.1

qual combinação de modelo e limiar minimiza o custo? Quanto ela economiza em relação a usar o mesmo modelo no corte 0,5?

PERGUNTA H.2

o limiar de custo mínimo coincide com o de F1 máximo? Explique a diferença olhando para os valores das fraudes que cada um deixa passar (`describe()` do Amount dos falsos negativos nos dois limiares).

ENTREGÁVEL · gráfico com as duas curvas de custo, tabela de varredura do modelo escolhido e os dois `describe()`.

i) Limitações e viés: onde o modelo erra e o que o dataset esconde

Com o modelo e o limiar escolhidos em h), cruze os erros com o contexto: recall por faixa de valor (Amount em quartis) e falsos positivos por 1.000 transações legítimas por hora do dia (`Time // 3600 % 24`).

PERGUNTA I.1

os erros estão distribuídos de forma uniforme? Quem paga a conta dos falsos positivos: todos os clientes ou um grupo específico?

PERGUNTA I.2

liste três limitações deste dataset que impedem de generalizar as suas conclusões para um banco brasileiro hoje. Pense em origem, período coberto, features transformadas e em como os rótulos foram produzidos.

ENTREGÁVEL · tabela de recall por faixa, gráfico por hora e as respostas.

j) Parecer operacional

Escreva, em no máximo 250 palavras, um parecer para o gestor do time de fraude recomendando modelo, limiar e regime de validação. O parecer deve conter cinco números do próprio notebook, incluindo ao menos um de custo, um de volume de alertas ou capacidade e um de recall. Termine com o que precisa ser monitorado depois da implantação.

ENTREGÁVEL · o parecer em Markdown no notebook e no relatório.

6. Entrega

- `avaliacao_<codigo>.ipynb` criado por você, executado de ponta a ponta, com um título por item (a a j) e as respostas discursivas em células Markdown logo abaixo do código de cada item.
- Relatório em PDF de até 6 páginas com as respostas b.1 a i.2, o parecer do item j) e os gráficos dos itens b), c), e), h) e i).
- A pasta `saida/` com `avaliacao_<codigo>_rf.joblib` e `avaliacao_<codigo>_teste.csv.gz`.

A entrega é individual ou em dupla, conforme a formação usada no Roteiro 2; no caso de dupla, uma entrega por dupla com os dois nomes. Os números do relatório são conferidos contra o seu dataset, com tolerância de 0,02 nas áreas e de um passo (0,05) nos limiares.

7. Rubrica

ITEM	CRITÉRIO	PONTOS
<i>a</i>	Limpeza equivalente à do Roteiro 2, split temporal correto, modelo e teste salvos com os nomes obrigatórios	<i>1,0</i>
<i>b</i>	Histograma por classe em escala log e leitura correta da zona de dúvida	<i>0,5</i>
<i>c</i>	As duas áreas e curvas corretas; recall da classe difícil calculado com o rótulo original; argumento sobre qual área usar	<i>1,0</i>
<i>d</i>	<code>varrer_limiares</code> correta e reutilizável; tabela completa; limiar de F1 máximo identificado	<i>1,0</i>
<i>e</i>	Custo por limiar correto; três limiares comparados; restrição de capacidade aplicada; análise de sensibilidade com FN cinco vezes maior	<i>1,5</i>
<i>f</i>	Validação cruzada e split temporal comparados; explicação do otimismo ligada ao Roteiro 2	<i>1,0</i>
<i>g</i>	Split temporal, dois modelos, duas áreas e matrizes; leitura da discordância entre as áreas	<i>1,0</i>
<i>h</i>	Custo com Amount por linha nos dois modelos; escolha justificada; explicação da diferença entre F1 máximo e custo mínimo com os <code>describe()</code>	<i>1,5</i>
<i>i</i>	Recall por faixa e FP por hora; três limitações concretas do dataset	<i>0,5</i>
<i>j</i>	Parecer com cinco números próprios, recomendação clara e itens de monitoramento	<i>1,0</i>
Total		<i>10,0</i>

Descontos. Números que não batem com o seu dataset além da tolerância: até 2,0 pontos. Coluna `alertas_ids` presente no modelo: 2,0 pontos. Arquivos de `saida/` ausentes ou com nome diferente do obrigatório: 1,0 ponto. Ausência do seu `random_state` em `fit` ou `split`: 0,5 ponto.

8. Leituras

- CHIO, C.; FREEMAN, D. *Machine Learning and Security*. O'Reilly, 2018. Capítulo 2

(classificação, limiares e trade-off entre precisão e recall) e seções do capítulo 1 sobre falsos positivos em operação.

- STALLINGS, W. *Criptografia e Segurança de Redes*. Pearson. Capítulo sobre intrusos: a falácia da taxa-base e a exigência de baixa taxa de falsos alarmes em detecção de intrusão.
- GÉRON, A. *Mãos à Obra: Aprendizado de Máquina com Scikit-Learn, Keras e TensorFlow*. 3. ed. Alta Books, 2023. Capítulo 3 (métricas, curvas PR e ROC, escolha de limiar).
- NIST AI 100-2e2025. *Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations*. Seções sobre avaliação e limitações de modelos em segurança.
- DAL POZZOLO, A. et al. *Calibrating Probability with Undersampling for Unbalanced Classification*. IEEE CIDM, 2015 (artigo de origem do dataset de fraude).

Fim da Avaliação Intermediária · Cibersegurança Aplicada com Inteligência Artificial · Insper 2026-2